



Auditoría de Seguridad e Integridad

Tenri ERP Cloud · Resumen Ejecutivo · 10-jun-2026 · Rama dev

Backend Laravel 12 + Sanctum · Frontend React 19 · MySQL 8 · Arquitectura DDD multitenant · Metodología: panel de 5 auditorías especializadas + verificación manual directa.

Veredicto general

Tenri ERP es un sistema **bien construido para su etapa**: arquitectura DDD por dominios, 204 archivos de test, CI/CD con PHPStan + PHPUnit, Sentry, backups, cifrado de material SII en reposo y RBAC granular en dos capas. Los riesgos detectados **no son de diseño roto**, sino de **garantías que aún dependen de disciplina manual** en lugar de capas centrales *fail-safe*. Cerrar P0/P1 deja al sistema listo para escalar contribuyentes y para conectar TGR / Previred / Cajas con seguridad regulatoria.

2 Críticos (●)	9 Altos (●)	11 Medios (●)	8 Bajos (●)	✓ Sin secretos reales en el historial
-------------------	----------------	------------------	----------------	--

Veredicto por dominio

DOMINIO	ESTADO	RIESGO RESIDUAL PRINCIPAL
Autenticación / Sanctum	● Aceptable con brechas	Login sin rate-limiting
Autorización / RBAC	● Bien diseñado (2 capas)	Validar techos de plan en escalada
Aislamiento multitenant	● Frágil por diseño	Scope global no es fail-safe; cobertura 6/51 modelos
Integridad contable	● Controles incompletos	Reclasificación / soft-delete sin candado de período
SII / criptografía	● Lo mejor logrado	Falta validar firma de respuestas / CAF
Secretos / CI-CD / config	● Higiene mejorable	Credenciales de prueba commiteadas; faltan headers

Top riesgos a cerrar primero (P0)

SEV	RIESGO	EVIDENCIA	CONF.
CRÍTICO	Login sin rate-limiting en /auth/login y /auth/token-login → fuerza bruta / credential stuffing ilimitado.	routes/api.php:55-56	✓
ALTO	Aislamiento multitenant frágil: EmpresaScope no filtra en jobs/consola/onboarding y solo 6 de 51 modelos lo usan.	Core/Scopes/EmpresaScope.php	✓
CRÍTICO	Contabilidad mutable: reclasificación de asientos y soft-delete de asientos/facturas pagadas sin candado de período cerrado.	FacturaService.php:238-283	✓/●
MEDIO	Credenciales de prueba commiteadas: superadmin@tenri.cl / password123 en .env.e2e y UserSeeder (×4 roles).	Frontend/.env.e2e:1-2	✓
ALTO	Sin cabeceras de seguridad (CSP/HSTS/X-Frame) + token en localStorage (XSS).	config / api.js	●

Confianza: ✓ verificado manualmente · ● reportado por revisión especializada (pendiente de validación puntual).

Fortalezas confirmadas

- **Cifrado SII en reposo:** certificados .pfx, contraseñas, clave RSA y XML del CAF cifrados con Crypt + marcados \$hidden.
- **SSO con HMAC-SHA256** con timestamp + nonce (anti-replay).
- **RBAC en dos capas:** gate por permiso en ruta + lógica relativa por instancia en controller.
- **Deploy por SSH/SCP** con claves en GitHub Secrets (el README dice "FTP": desactualizado).
- **Sin .env/certificados/claves ni secretos reales** en el árbol ni en 347 commits de historial.
- **CORS con orígenes explícitos** (sin wildcard) · bcrypt rounds 12 · partida doble validada · DECIMAL (15, 2).

Plan de acción priorizado

P0 — Bloqueantes (esta semana)

ACCIÓN	ESFUERZO
throttle en login y endpoints internos.	S
Rotar credenciales superadmin/password123; quitar .env.e2e del repo/historial; randomizar seeder.	S/M
EmpresaScope fail-safe (denegar si no hay tenant en contexto web).	M
Candados de estado/período en reclasificación y soft-delete contables (*requiere diseñar feature de bloqueo de período).	M

P1 — Hardening multitenant (2-4 semanas)

- Aplicar HasEmpresaScope a los 45 modelos restantes + extender test de aislamiento a todos.
- Middleware global de cabeceras de seguridad; migrar token a cookie HttpOnly o endurecer CSP.
- Máquina de estados de factura + FK movimientos_bancarios.asiento_id; retirar fallback legacy X-WEB-API-KEY.

P2 — Robustez SII (1-2 meses)

- Validar firma del CAF y de respuestas SOAP contra CA raíz del SII; job de expiración de CAF; mitigar XXE.
- Auditoría a nivel de campo (montos/fechas); rotación documentada de APP_KEY.

P3 — Higiene (continuo)

- Ignorar_ide_helper*.php; borrar an_optimizeclear; pre-commit con gitleaks; **actualizar README**.

Preparación para TGR · Previred · Cajas de Compensación

Regla de oro: resolver el aislamiento multitenant (P0/P1) **antes** de conectar datos previsionales/fiscales — una fuga cross-tenant ahí sería incidente regulatorio.

- **Base ya existente:** dominios DDD aislados + patrón de integración por eventos (outbox) en Inventario y SII.
- **Generalizar** la capa de credenciales cifradas del SII como servicio común reutilizable por cada organismo.
- **Adaptador por organismo** (interface + adaptadores sandbox/producción) con feature flags por plan.
- **Cola + outbox** para toda integración externa (idempotencia, reintentos, dead-letter); exige cache/locks en database/redis.
- **Verificación criptográfica** de respuestas y **auditoría a nivel de campo** como requisitos transversales.